

Reporting & Professional Communication

Module 5 — Putting It Together · Unit 17

The client isn't buying the hack. They're buying the **report**.

Learning objectives

By the end of this unit, you can:

- **Explain** why the written report is the real deliverable of a pentest.
- **Identify** the standard report sections: executive summary, methodology, findings, remediation, appendices.
- **Write** an executive summary for a leader **and** a technical finding for IT staff — from the same issue.
- **Assign** a severity (Low/Med/High/Critical) and justify it by likelihood × impact.
- **Document** a finding with evidence, impact, and specific remediation.
- **Explain** the ethics of accurate reporting — no exaggeration, no hiding.
- **Produce** a complete sample report and receive your **capstone** assignment.

The big idea: clients pay for the report

- A brilliant test with a sloppy report is a **failed engagement**.
- The client makes real decisions and spends real money based on what you write.
- A finding that isn't clearly written and reproducible **effectively doesn't exist** for the client.

Two weeks of brilliant hacking + a one-paragraph email = the client did **not** get what they paid for.

Report anatomy

Section	Purpose	Audience
Executive summary	The "so what" in plain language	Busy, non-technical leaders
Methodology	How the test was done (the phases)	Anyone
Findings	Each issue: evidence, severity, impact	Technical staff
Remediation	Specific, actionable fixes	Technical staff
Appendices	Raw tool output, references	Reference

Plus a restated **scope & authorization** — the written proof the test was permitted.

A report outline

1. Executive summary (plain language – how exposed are we?)
2. Methodology (recon → scan → exploit → document)
3. Findings
 - 3.1 Finding 1 – title, asset, severity, evidence, impact
 - 3.2 Finding 2 – ...
4. Remediation & recommendations
5. Appendices
 - A. Raw tool output (nmap, gobuster)
 - B. References (CVE, OWASP, CVSS)

Number your findings. Label every screenshot. Use consistent terms.

5

Anatomy of a single finding

Every finding must include:

- **Title** — clear, specific ("not the website is bad").
- **Affected asset** — host, IP, or URL.
- **Evidence** — labeled screenshots + exact commands so a reader can reproduce it.
- **Severity** — Low / Med / High / Critical, *justified*.
- **Impact** — what an attacker could actually do to the organization.
- **Remediation** — the specific fix.

"Trust me, it worked" is not evidence. Label every figure: "Figure 1: login form accepts ' OR 1=1 --'".

Severity: likelihood × impact

Rating	Rough meaning	Example
Critical	Easy AND severe	Unauth RCE; SQLi dumping the user table
High	Serious, takes some effort	Stored XSS stealing admin sessions; default admin password
Medium	Real risk, limited or harder	Reflected XSS needing a click; directory listing
Low	Minor, little direct impact	Verbose error leaking a version; missing header

Severity inflation is the #1 error. Not everything is Critical — justify every rating.

CVSS (awareness level)

- **CVSS** = Common Vulnerability Scoring System.
- An industry method that turns factors into a **0-10 score**.
- It considers things like **how easy** the attack is and **how much damage** it does.

You don't need to compute vectors by hand. Just know it **exists** and roughly what feeds it. (Online calculators do the math.)

Writing for two audiences

Same truth, different altitude.

	Executive summary	Technical finding
Reader	Non-technical leader	IT staff who will fix it
Length	Short (2-4 sentences)	Detailed, reproducible
Language	Plain — no jargon	Precise, exact commands
Answers	"How exposed are we? What do we do?"	"Exactly what, where, and how to fix"

Executive: *"A login page let us read the customer database. We recommend fixing it immediately."*

Technical: *"Unsanitized input in the login form permits UNION-based SQL injection."*

Remediation: be specific

-  "Make it more secure."
-  "Use **parameterized queries** for all database calls."
-  "**Change the default admin password** and enforce a strong-password policy."
-  "**Validate and sanitize** all user input server-side."

A fix the IT team can act on tomorrow. Vague advice is worthless to the client.



Ethics & Authorization

Accuracy is an ethical duty.

Two failures, equally serious:

- **Exaggerating** a finding to look impressive (crying wolf, wasting their money).
- **Minimizing or hiding** a finding because it's awkward or you ran out of time.

The report is also the **written record that the test was authorized and in scope.**

Key vocabulary

Term	Meaning
Deliverable	What the client receives and pays for — the report
Executive summary	Short, plain-language overview for leaders
Methodology	How the test was done (the phases)
Finding	One issue, with evidence, severity, impact
Evidence	Proof — labeled screenshots, commands, hosts
Severity	Low / Med / High / Critical
Likelihood × Impact	How easy to exploit × how bad if exploited
Remediation	The specific, actionable fix



Lab launch — write a sample report

- **No new attacking.** You write up a finding you **already** produced in an earlier authorized lab (Unit 07 OSINT, Units 10–12 web, or Unit 15 privesc).
- **Read the Safety & authorization reminder aloud** with a partner.
- Fill in the **report template**: all five sections + one full finding.
- **Restate scope/authorization** at the top.
- **Peer-review** against the report rubric — one glow, one grow — then revise and submit.

Report only what actually happened. No inventing. No new commands to "get a better screenshot."



Capstone kickoff

Next week: your team runs the **full attack lifecycle** on an authorized target — then reports and presents.

- **Target:** a **picoCTF** set and/or an approved **TryHackMe** room — *approved list ONLY.*
- **Deliverables:** lab journal → full report → 3–5 minute presentation.
- **Today:** confirm your team, your target, and write your **scope statement**.

Recap

- The **report is the real deliverable** — clients pay for it, not the hack.
- Five sections: **exec summary, methodology, findings, remediation, appendices.**
- Every finding: **evidence + justified severity + impact + remediation.**
- **Severity** = likelihood × impact; don't inflate. **CVSS** exists (awareness).
- Write for **two audiences** — same truth, different altitude.
- **Accuracy is an ethical duty:** no exaggerating, no hiding.
- **Capstone** kicks off next week — confirm your team, target, and scope.

Exit ticket / discussion

1. Name the five report sections. Which does a non-technical CEO read first?
2. What three things must every finding include?
3. Rewrite for an executive: *"Unsanitized input in the login form permits UNION-based SQL injection."*
4. Why is **accuracy** an ethical duty — give one harm from exaggerating and one from hiding.

Each team submits: target name, members, and a one-sentence scope/authorization statement.